OTPROOF

Check which public security notices may affect industrial equipment, then keep the human review and evidence together.

80	3	0
fictional assets	real CISA advisories	OT device actions

The idea

Turn public industrial security advisories and operator-maintained asset lists into a reviewable, evidence-backed workflow. Deterministic rules identify exact product and version candidates; people resolve uncertainty and verify remediation.

A practical, safety-conscious MVP

A local dashboard, validated CSV/XLSX inventory import, official public-source ingestion, explainable applicability, engineer/reviewer/approver workflow, audit trail, and assurance report. No OT network interaction is required.

Eureka Hackathon · Product concept and working MVP · 26 October 2026

OTProof in plain language

It connects an equipment list to public security notices. It points people to records worth checking; it does not touch equipment or make operational decisions.

A simple example

A real CISA notice says FactoryTalk View Site Edition version 13.0 is affected. In our fictional water utility, asset CV-HMI-001 is version 13.0.0, so OTProof shows a possible match and links the notice. CV-HMI-002 is version 14.0, which is outside that notice's version statement. CV-HMI-005 has no recorded version, so OTProof asks an engineer to check. None of these results means equipment was changed or fixed.

People make the important calls

A reviewer decides whether the notice fits the asset and records why. An engineer proposes any work and its timing. An approver accepts or rejects that plan. After work, the team adds evidence and an approver verifies it. AI can help read the notice, but it cannot make those decisions.

Quick translations

OT means operational technology: computers and controllers that monitor or run physical processes such as water pumps. A vulnerability notice describes a software or product weakness. A CVE is the public ID assigned to a specific vulnerability. Evidence is a record that supports a human decision, such as a change reference or test result.

OTProof is a careful checklist and record keeper: it highlights what may need attention, while authorized people decide what to do.

Worked example source: CISA ICSA-24-226-06 · https://www.cisa.gov/news-events/ics-advisories/icsa-24-226-06

The inventory and the security notice speak different languages

A public vulnerability notice alone does not say which equipment at a particular site needs engineering attention.

Three records that rarely line up cleanly

Operators track equipment names, models, software versions, locations, importance, and owners in spreadsheets and maintenance systems. Security notices may use different product names and list affected versions in a different format. Security and engineering teams have to compare the records and keep track of their reasoning.

False certainty has a cost

A loose name match can create false alarms. Missing or old version details can hide a real concern. Before changing industrial equipment, the team must consider process impact, vendor guidance, maintenance schedules, and safety.

Why now

NIST's final OT security guide recommends keeping accurate records of equipment, vendors, software versions, locations, and responsible roles. OTProof starts from a file the operator provides and does not connect to industrial equipment.

The product shows a possible match with its source. It does not decide whether a change is safe or whether work is complete.

From security notice to reviewed evidence

Every finding preserves the records and decisions needed to explain what happened.

1 · Load and validate inventory

Load an inventory spreadsheet with each asset's ID, maker, product/model, software version, type, site, importance, owner, and last check date. OTProof checks required fields and rejects duplicate IDs, very large uploads, and macro-enabled workbooks.

2 · Import approved advisory data

Load public security notices from CISA, the CISA list of known exploited vulnerabilities, NIST's vulnerability database, or an approved vendor website. OTProof saves when and where each record came from so the team can check it later.

3–6 · Compare, review, and assure

The comparison returns one of three results: likely affected, does not match this notice, or needs a human check. A reviewer records the decision and reason. An engineer proposes work, an approver reviews it, and later an approver checks the supporting evidence. Reports preserve the sources and action history.

A proposed fix or AI-written summary cannot count as proof that work is complete. An authorized person must check evidence.

How the application is built

One maintainable service keeps source ingestion, comparison, workflow, and evidence close together.

Built for the demo and a controlled pilot

A web dashboard sends requests to one service that validates data, applies matching rules, and records decisions in a database. The implementation uses React/TypeScript, FastAPI/Pydantic, and PostgreSQL; SQLite supports a quick local demo. ReportLab creates PDF reports, and Docker Compose packages the components.

Public sources only

The source service uses documented public CISA and NIST feeds, CISA-linked advisory files, and approved vendor websites. It avoids unnecessary repeat downloads, retries temporary rate limits, and can use a saved older copy when a source is unavailable.

What the system can and cannot do

There is no connection to industrial devices, no network scanner, no exploit tool, and no way to change equipment. The optional local AI helper can read notice text and draft fields, but it cannot decide whether a vulnerability applies or mark work complete.

Before a real operator uses it: add company login, protect and rotate secrets, limit internet access, test backup and restore, and complete an independent security review.

The matching rules show their work

OTProof compares product identity and published version limits. If it cannot tell, it asks a person to check.

Supported comparisons

A small reviewed list handles known spelling variations. The product name must match, then the installed version is compared with the affected version or range stated by the publisher. Every required condition must match; separate affected products are checked as separate possibilities.

Abstain when evidence is incomplete

Missing software version, unknown model, a possible duplicate asset, inventory older than 180 days, unfamiliar version format, unclear product identity, or complicated source conditions all require an engineering review. A similar-sounding name is never enough to call a vulnerability applicable.

AI assists with reading, not deciding

An optional AI model running on the user's computer can suggest product, version, vulnerability ID, mitigation, and summary fields. Required fields are checked and quoted details are compared with the original notice. The AI suggestion does not affect the matching result or workflow status.

No AI model was run during evaluation. Its accuracy has not been measured; a person must check every suggestion.

People review work and verify evidence

Separate technical applicability, remediation planning, approval, and evidence verification.

Role-gated lifecycle

The reviewer checks whether the notice applies and records the reason. The engineer proposes a safe action, an owner, and a due date. A different person approves or rejects the plan. After the work, the team adds a change or test record; an approver checks it and records why it is sufficient.

Audit and exports

The system records who did what and when. The report includes the source publication and update dates, matching reasons, human decisions, work status, evidence references, and action history. Evidence records include a digital fingerprint so later changes can be detected when compared with the original.

What the MVP does not claim

The demo passwords are visible and unsafe for real use. A database administrator could change stored audit records. Evidence is a text record or reference, not an uploaded file. OTProof does not certify compliance or prove that operational risk was reduced.

Demo evidence is fictional. Marking it verified changes the demo record only; it does not prove a real plant change occurred.

Potential customers and business model

Potential users span operators, contractors, and service providers with different inventory systems.

Interview targets

Water and wastewater utilities; energy operators; oil and gas infrastructure; industrial maintenance contractors; managed OT security service providers; and defense-support facilities. Likely champions are OT security leads, plant engineering managers, asset owners, CISOs, and service-practice owners.

Competitive landscape

Claroty, Tenable, and Nozomi publicly describe broad industrial equipment visibility, vulnerability management, monitoring, and remediation workflows. ServiceNow and similar risk and compliance systems manage controls, audits, and work records. OTProof may offer a local, source-linked review workflow that complements them; this is a hypothesis, not a proven advantage. Better evidence handover may help audit preparation, but compliance outcomes and risk reduction have not been measured.

Illustrative annual revenue model

For illustration only, assume 3 sites per customer at $36,000 per site each year, $25,000 one-time setup for each new customer, and assumed profit margins of 78% on software and 40% on setup services. These are arithmetic examples, not sales, market size, or a forecast.

Customers	Sites	Recurring ARR	Year-1 revenue	Year-1 gross profit
1	3	$108k	$133k	$94k
5	15	$540k	$665k	$471k
10	30	$1.08m	$1.33m	$942k
25	75	$2.70m	$3.33m	$2.36m

ARR means yearly subscription income. Gross margin is the share left after direct delivery costs; gross profit is that amount in dollars. Prices and margins need buyer interviews and cost validation.

Measured MVP, open questions, and the next proof points

The first test is repeatable behavior against labeled edge cases—not a broad product claim.

Fixture baseline (26 Oct 2026)

The test set has 14 hand-labeled asset/notice examples: 4 likely affected, 4 outside the published affected details, and 6 that should go to human review. The matcher returned the expected result on all 14. It found all 4 affected examples and missed none in this small test set. It also sent all 6 uncertain examples to review. Each result kept the source ID, link, and relevant source text.

Performance and security checks

A single local software-only run compared 80 fictional assets with 3 notices (240 comparisons) in about 1.01 ms. This does not include internet, database, or human review time. Tests cover unavailable sources, duplicate IDs, unsafe spreadsheets, unsupported AI claims, role permissions, and evidence review.

Roadmap and pilot ask

Next, invite 3–5 operators and service providers to test the workflow. Ask engineers to label examples before seeing OTProof's results, then compare disagreements. Measure missed cases, human-review cases, time per review, and setup effort across several vendors. Add company login, protected audit export, and maintenance/risk-system connections only after users confirm the need. Ask a water or energy operator and its engineers to join this evaluation.

Not measured yet: operator accuracy, human review time, AI quality, savings, or production performance.

NIST SP 800-82 Rev. 3 final: https://csrc.nist.gov/pubs/sp/800/82/r3/final
CISA advisory fixture provenance: data/fixtures/SOURCES.md
Technology and competitive references: docs/TECHNOLOGY_DECISIONS.md and docs/RESEARCH_NOTES.md